ASSESSMENT TOOL III – ASSIGNMENT

COURSE CODE: ITA14 COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENT QUESTION

11. A security researcher publicly releases a working exploit for a vulnerability before the vendor has issued a patch, arguing that public pressure is the only way to force a fix. Discuss whether this qualifies as ethical hacking, and where this person falls on the hacker spectrum.

ANSWER

1. Introduction

Ethical hacking is the authorized and responsible practice of identifying, analyzing, and reporting security weaknesses so that organizations can correct them before attackers misuse them. Ethical hackers work within defined legal and professional boundaries and are expected to minimize harm while improving security. One of the most important principles in this area is responsible disclosure, where a researcher gives the affected vendor an appropriate opportunity to investigate the vulnerability, develop a patch or mitigation, and protect users before detailed information is released publicly.

The situation in this question is more complicated because the researcher has publicly released a working exploit before the vendor has issued a patch. The researcher claims that public pressure is necessary to force the vendor to act. This creates a conflict between the public's interest in knowing about serious vulnerabilities and the responsibility to avoid exposing users to preventable attacks. Therefore, the researcher's intention, authorization, disclosure process, technical details released, and potential consequences must all be considered before classifying the conduct.

2. Does the Discovery Qualify as Ethical Hacking?

The discovery of the vulnerability can qualify as ethical hacking when the researcher identified the weakness through an authorized security assessment, a legitimate bug-bounty program, or another legally accepted research activity. Ethical hacking is not defined only by the use of security tools or the discovery of a technical flaw. Authorization, purpose, scope, and responsible conduct are important parts of the activity.

If the researcher was authorized to test the system and initially reported the vulnerability appropriately, the vulnerability research itself can be considered ethical. The ethical concern arises from the later decision to release a working exploit before a patch was available. This distinction is important: finding a vulnerability responsibly and publishing an immediately usable exploit are two separate actions.

Therefore, the researcher's original security research may be ethical while the method of public disclosure may violate responsible-disclosure principles.

3. The Problem with Releasing a Working Exploit Before a Patch

A working exploit is significantly more dangerous than a general vulnerability description because it can reduce the technical knowledge and effort required for another person to reproduce the attack. Before a patch exists, affected users may have no practical way to eliminate the vulnerability. Public release at this stage can therefore increase the likelihood of exploitation by malicious actors.

For example, if a vulnerability affects a widely deployed application, an attacker could use the published exploit to target organizations that have not yet had an opportunity to apply a security update. The original researcher may not intend to cause harm, but ethical responsibility also requires considering foreseeable consequences.

The researcher should therefore distinguish between making the existence of a vulnerability known and publishing complete exploit instructions or code. Public awareness can sometimes be justified, while releasing highly actionable exploit material before mitigation is available requires a much stronger ethical justification.

4. Is Public Pressure Ever Justified?

The researcher's argument cannot be dismissed completely. Vendors may sometimes delay remediation, fail to respond to researchers, or underestimate the seriousness of a vulnerability. In such circumstances, a researcher may believe that public disclosure is necessary to protect users and create accountability.

However, public pressure should normally be applied through controlled and proportionate disclosure. The researcher should first make reasonable attempts to contact the vendor, clearly explain the vulnerability and its severity, document communication attempts, provide sufficient technical information for verification, and allow a reasonable period for remediation. If the vendor remains unresponsive, escalation to an appropriate vulnerability coordination organization or other responsible channel may be considered.

Even when public disclosure becomes justified, the researcher should minimize unnecessary risk. This could mean publishing the existence and impact of the vulnerability, recommended mitigations, and affected versions while withholding a complete working exploit until users have a reasonable defensive option.

5. Responsible Disclosure and Coordinated Disclosure

Responsible disclosure is based on cooperation between the researcher and the affected organization. The researcher reports the vulnerability privately, the organization investigates and develops a solution, and public information is released after reasonable coordination.

Coordinated disclosure follows the same basic objective but emphasizes communication among relevant parties, especially when multiple vendors, maintainers, or downstream users are affected. This is particularly important when a vulnerability exists in widely used software or infrastructure.

In the given situation, the researcher should have attempted private disclosure first. If the vendor failed to respond, the researcher could establish a reasonable deadline and communicate that limited public disclosure may follow. The goal should be to encourage remediation rather than to maximize publicity or create immediate opportunities for exploitation.

6. Classification on the Hacker Spectrum

The hacker spectrum is commonly discussed using categories such as white hat, grey hat, and black hat. White-hat hackers operate with authorization and with the objective of improving security. Black-hat hackers operate without authorization and generally have malicious, criminal, or harmful objectives. Grey-hat hackers fall between these categories and may discover or test vulnerabilities without full authorization, or may have legitimate intentions while using methods that cross ethical or legal boundaries.

The researcher in this scenario is best placed in the grey-hat category if the person has a legitimate security objective but publicly releases a working exploit in a manner that violates responsible-disclosure expectations. The classification is based on both intention and conduct.

If the researcher had authorization, followed the agreed rules, and only released carefully limited information after reasonable coordination, the researcher could remain within the white-hat/security-researcher category. On the other hand, if the researcher intentionally released the exploit to facilitate attacks, obtain unauthorized access, damage systems, or gain illegal profit, the conduct could move toward the black-hat category.

7. Why Intention Alone Is Not Enough

The researcher's claim that public pressure is the only way to force a fix is relevant, but intention alone does not determine whether conduct is ethical. A person may have a positive objective but still choose a method that creates unacceptable risks.

Ethical hacking requires balancing several considerations: authorization, legality, confidentiality, potential harm, proportionality, professional responsibility, and the interests of affected users. A researcher who wants to improve security should therefore select the least harmful effective method.

In this case, the researcher could argue that public disclosure protects users by forcing the vendor to respond. However, the same disclosure could also help attackers exploit users before the vendor can issue a patch. The ethical quality of the decision therefore depends on whether the researcher took reasonable steps to reduce that risk.

8. Ethical Principles Applicable to the Scenario

Several foundational ethical hacking principles apply to this situation:

• Authorization: Security testing should be performed only with appropriate permission and within an agreed scope.

• Responsibility: A researcher should act professionally and consider how technical information may affect users and organizations.

• Non-maleficence: The researcher should avoid unnecessary harm and should not create additional security risks merely to demonstrate a point.

• Beneficence: Security research should aim to improve protection, reduce vulnerabilities, and benefit affected users.

• Confidentiality: Sensitive vulnerability information and exploit material should be protected until disclosure is reasonably safe.

• Responsible disclosure: Vendors should normally be given a reasonable opportunity to investigate and remediate vulnerabilities.

• Proportionality: The method used to pressure an unresponsive vendor should be proportionate to the severity of the problem and should minimize collateral harm.

• Professional integrity: Researchers should document their actions and be prepared to justify why their disclosure approach was necessary and responsible.

9. Possible Consequences of Premature Exploit Disclosure

Premature publication can have several consequences. Malicious attackers may copy the exploit and target vulnerable systems. Organizations that depend on the affected software may not have enough time to deploy mitigations. Security teams may be forced to respond to attacks while the vendor is still developing a patch. Customers may also lose trust in both the vendor and the researcher.

There may also be legal consequences depending on the jurisdiction, the researcher's authorization, the systems involved, and how the exploit was obtained or used. A researcher should therefore understand the legal conditions surrounding security research before testing or disclosing vulnerabilities.

At the same time, keeping a vulnerability completely secret forever can also leave users exposed when the vendor refuses to act. This is why responsible disclosure seeks a practical balance between vendor remediation, public awareness, and user safety.

10. Recommended Ethical Course of Action

A responsible researcher should follow a structured process. First, verify the vulnerability without causing unnecessary damage. Second, determine whether the testing was authorized and identify the affected products and systems. Third, contact the vendor through its official security contact or vulnerability disclosure program. Fourth, provide enough information to allow the vendor to reproduce and understand the issue. Fifth, maintain records of communication and allow a reasonable remediation period.

If the vendor does not respond, the researcher can escalate the issue through an appropriate coordination channel. If public disclosure becomes necessary, the researcher should disclose information that helps users protect themselves while avoiding unnecessary release of a complete working exploit. If a proof of concept is necessary, it should be carefully limited and designed to reduce the risk of misuse.

This approach preserves the public-interest objective of security research while reducing the chance that the researcher becomes the source of additional harm.

11. Overall Ethical Evaluation

The scenario should not be judged solely by whether the researcher is technically correct or whether the vendor is behaving responsibly. Both parties have responsibilities. The vendor should take legitimate vulnerability reports seriously and work toward timely remediation. The researcher should communicate clearly, provide reasonable time for remediation, and avoid unnecessarily increasing the risk to users.

The strongest ethical concern is the release of a working exploit before a patch is available. If the exploit is immediately usable against real systems, publication can materially increase the threat faced by users. Public pressure may be understandable when a vendor is unresponsive, but it should normally be the result of controlled escalation rather than the immediate publication of weaponizable material.

12. Conclusion

The security researcher may qualify as an ethical hacker in terms of the original vulnerability research if the discovery was authorized and intended to improve security. However, releasing a working exploit before the vendor has issued a patch conflicts with the principles of responsible and coordinated disclosure because it may expose users to attacks that could otherwise have been prevented or mitigated.

On the hacker spectrum, the researcher is most appropriately described as a grey-hat hacker when the motive is defensive or public-interest oriented but the disclosure method is unauthorized, irresponsible, or ethically questionable. If the researcher had followed authorization requirements and a responsible disclosure process, the person would more closely fit the white-hat category. If the exploit were released or used with malicious intent, for financial gain, or to facilitate unauthorized attacks, the conduct could fall into the black-hat category.

Therefore, ethical hacking is not determined only by good intentions. It also depends on authorization, responsible disclosure, professional conduct, proportionality, and the researcher's effort to protect affected users from unnecessary harm.

Code of Conduct

I Karanam Reddy Vishnu Chaithanya/192372057 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem Solving Approach	20	Logical, well structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand